

TaxScout Information Security Policy

Effective date: August 18, 2026

Owner: Founder, TaxScout (sole operator; no dedicated security team)

Contact: ajaaronday21@outlook.com

1. Purpose and Scope

This policy describes how TaxScout identifies, mitigates, and monitors information security risk in the systems that store or process user data, including data obtained via third-party financial data providers (e.g. Plaid). It applies to all production systems: the TaxScout web application, its database, and its hosting/infrastructure providers.

2. Data Handled

- Account credentials (email/password, via Supabase Auth)
- Financial transaction data (via Plaid, read-only)
- Plaid access tokens (used to fetch transaction data on the user's behalf)
- Basic profile data (state, income range, for tax estimation)

TaxScout never receives or stores end users' bank login credentials. Plaid handles credential collection directly with the financial institution; TaxScout only receives a scoped access token after the user completes that flow.

3. Access Control

- All database access is governed by row-level security (RLS) in Postgres (Supabase). Authenticated users can only read/write their own rows.
- Plaid access tokens are stored in a table with no client-side read access under RLS. Tokens are only readable by server-side code using a service-role key, which is never exposed to the client and is stored as an encrypted secret in the hosting provider's (Cloudflare) secret store.
- No shared logins. Each user authenticates individually via Supabase Auth.

4. Data in Transit and at Rest

- All traffic between users and TaxScout is encrypted in transit via HTTPS/TLS.
- All application data is stored in Supabase's managed Postgres, which encrypts data at rest as part of its infrastructure.

5. Third-Party Data Providers

- **Plaid:** used solely for the Transactions product, read-only. TaxScout requests only the minimum product scope needed and does not request Auth, Identity, Assets, Income, Investments, or other Plaid products it does not use.
- **Stripe:** used for payment processing. TaxScout never receives or stores card numbers; all payment data is handled by Stripe directly.
- **Supabase:** used for authentication and database hosting.

- **Cloudflare:** used for application hosting and secret storage.

6. Account and Token Revocation

Users can disconnect a linked bank account at any time from Settings. On disconnect, TaxScout immediately calls Plaid's `/item/remove` endpoint to revoke the associated access token and deletes the corresponding record from its database.

Users can delete their account and associated data from Settings, which removes their profile, transactions, and any linked-account records.

7. Incident Response

1. The affected system or credential is isolated or rotated immediately (e.g. revoking Cloudflare secrets, rotating Supabase service-role key).
2. The scope of affected data is assessed.
3. Affected users are notified without undue delay once the scope is known.
4. A summary of the incident and remediation is documented internally.

8. Risk Monitoring

- Dependencies are reviewed for known vulnerabilities on an ongoing basis.
- Access to production secrets (Cloudflare, Supabase, Plaid, Stripe) is limited to the founder; no third parties currently hold production credentials.
- This policy is reviewed and updated as the product, infrastructure, or team changes.

9. Certifications

TaxScout does not currently hold SOC 2 or other third-party security certifications. This policy reflects current practice and will be expanded as the company and its compliance needs grow.